

Cpts 327 Lab 1 Quiz

Instructions

- **Format Requirement:** Please round (nor floor or ceil) all numerical answers to **two decimal places** (Please use fractions in intermediate steps to avoid precision loss and only round at the very end), e.g., round the result 4.555 to 4.56, 4.444 to 4.44. If your calculated answer has fewer than two decimal places (e.g., 0.1), you must pad it with a trailing zero (e.g., enter **0.10**) to ensure the grading system accepts it.
-

Question 1: (3 Points) A buffer overflow occurs when a program writes data beyond the allocated memory boundary.

- **A. True.**
- **B. False.**

Question 2: (3 Points) The function `gets()` checks input length to prevent overflow.

- **A. True.**
- **B. False.**

Question 3: (3 Points) Which function is most likely to cause a buffer overflow?

- **A. fgets**
- **B. gets**
- **C. strcpy**
- **D. strlen**

Question 4: (3 Points) Using `scanf("%s", buf)` may cause buffer overflow if input is too long.

- **A. True.**
- **B. False.**

Question 5: (3 Points) Which statement about `strncpy` is correct?

- **A. Always safe**
- **B. Always null-terminates the string**
- **C. May not append a null terminator**
- **D. Does not limit copy length**

Question 6: (3 Points) Buffer overflow can only occur on the stack.

- **A. True.**
- **B. False.**

Question 7: (3 Points) Which of the following is NOT a typical consequence of buffer overflow?

- **A. Program crash**
- **B. Data corruption**
- **C. Arbitrary code execution**
- **D. Automatic memory repair**

Question 8: (6 Points) Which statement is correct for the code below?

```
char buf[10];  
fgets(buf, 10, stdin);
```

- **A. It will always overflow**
- **B. It reads no input**
- **C. It reads at most 9 characters (or until a newline) and always appends a null terminator**
- **D. It behaves the same as gets**

Question 9: (6 Points) An attacker can overwrite the return address via buffer overflow to control program execution.

- **A. True.**
- **B. False.**

Question 10: (7 Points) Consider the following code running on a system with NX and ASLR enabled, but no stack canary:

```
void vulnerable() {  
    char buf[64];  
    gets(buf);  
}
```

If an attacker successfully exploits this vulnerability, what is the most likely attack method?

- **A. Inject shellcode into the stack and execute it directly**
- **B. Overwrite return address and redirect execution to existing code (e.g., libc)**
- **C. The system will automatically prevent exploitation**
- **D. It can only cause a crash, not an exploit**

Cpts 327 Lab 3 Quiz

Instructions

- **Format Requirement:** Please round (nor floor or ceil) all numerical answers to **two decimal places** (Please use fractions in intermediate steps to avoid precision loss and only round at the very end), e.g., round the result 4.555 to 4.56, 4.444 to 4.44. If your calculated answer has fewer than two decimal places (e.g., 0.1), you must pad it with a trailing zero (e.g., enter **0.10**) to ensure the grading system accepts it.
-

Question 1: (3 Points) Why is it necessary to use LLMs to generate high-quality vulnerability data for Deep Learning (DL) security models?

- A) LLMs are naturally more secure than human coders.
- B) High-quality, labeled vulnerability data is scarce and expensive to find manually.
- C) DL models prefer synthetic data over real-world examples.
- D) LLMs automatically remove all security flaws from training sets.

Question 2: (3 Points) **True or False:** In the context of SQL Injection, the core semantic vulnerability is the failure to separate user data from command logic.

Question 3: (3 Points) According to the experimental metrics discussed, an LLM-generated vulnerability is considered "Successful" only if it is both:

- A) Complex and hard to detect.
- B) Vulnerable (contains the flaw) and Stable (preserves original functionality).
- C) Written in C and documented with comments.
- D) Zero-shot and safe from hallucinations.

Question 4: (3 Points) **True or False:** ICL (In-Context Learning) is a pattern-matching technique where the LLM is provided with a few examples ("shots") to guide its output.

Question 5: (3 Points) Which prompting strategy requires the model to provide a "step-by-step reasoning process" before outputting the final code change?

- A) Standard Prompting.
- B) Input Filtering.
- C) VICS / Chain-of-Thought (CoT).
- D) Few-shot ICL.

Question 6: (3 Points) **True or False:** Using an `AGENTS.md` file allows a coding agent to pre-fill its context with persistent rules and instructions across different sessions.

Question 7: (3 Points) **True or False:** In the RAG Triad, "Groundedness" measures whether every claim in the LLM response can be attributed to a document in the knowledge corpus.

Question 8: (3 Points) Why is the BM25 algorithm specifically utilized in RAG-based vulnerability detection tasks?

- A) It is a generative model that creates new code.
- B) It focuses on keyword overlaps and rarity (IDF) to precisely match library functions like `strcpy` or `sprintf`.
- C) It summarizes long chat histories into a single sentence.
- D) It is the primary method for training LLM weights via RLHF.

Question 9: (3 Points) **True or False:** The Model Context Protocol (MCP) is primarily used to summarize the prefix of a conversation when the history grows too long.

Question 10: (3 Points) In an advanced agentic architecture, why is "Parallelism" ($N = 5$) used when attempting vulnerability injection?

- A) To reduce the total time it takes for a single LLM to respond.
- B) To bypass the need for an Attacker subagent.
- C) To overcome the stochastic nature of LLMs by generating multiple paths and filtering for the best result.
- D) To ensure the agent can read/write Notion documents.

Basic SQL Injection Quiz

10 multiple-choice questions. One correct answer for each question. No answers are shown in this version.

1. What is SQL injection?

- A. A way to speed up database queries
- B. A technique that changes the SQL command by using crafted input
- C. A method for encrypting passwords
- D. A tool for backing up databases

2. Why is a login form vulnerable to SQL injection?

- A. Because the page loads too slowly
- B. Because the database is too large
- C. Because user input is directly inserted into the SQL query
- D. Because the password is too short

3. In SQL injection, what does an always-true condition like '1'='1' do?

- A. It makes the query return no rows
- B. It can make the login check succeed unexpectedly
- C. It deletes the database
- D. It encrypts the query result

4. What is the main goal of an SQL injection attack?

- A. To make the website look better
- B. To change or control the SQL query executed by the database
- C. To increase internet speed
- D. To compress database files

5. What can happen if an attacker injects SQL into an UPDATE statement?

- A. They may change data they should not be allowed to change
- B. They can only change browser settings
- C. They can only view public data
- D. Nothing will happen

6. Which symbol is often used to comment out the rest of an SQL statement?

- A. //
- B. --
- C. ##
- D. %%

7. If a WHERE clause becomes always true, what may happen?

- A. Only one safe row is updated
- B. Many rows may be returned or updated
- C. The server automatically shuts down
- D. The query becomes encrypted

8. Which database system is used in the lab?

- A. MySQL
- B. Oracle
- C. PostgreSQL
- D. SQLite

9. Which is the best defense against SQL injection?

- A. Use longer usernames
- B. Restart the server every day
- C. Use parameterized queries or prepared statements
- D. Hide the login button

10. Where is malicious SQL input most commonly entered by an attacker?

- A. Into a web form or URL parameter
- B. Into a monitor cable
- C. Into the computer battery
- D. Into the printer tray